

INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY

INTRO TO CRITICAL INFRASTRUCTURE FOR IT LEARNERS

LAB 07 — EXPLORING ICS PACKET CAPTURES

Student Edition

Authorized ICDFA training environments only
icdfa.edu.ng

Lab 07: Exploring ICS Packet Captures

Course: Intro to Critical Infrastructure for IT Learners | **Estimated Duration:** 4–5 hours

Submission deadline: As published in ICDFA E-Campus.

Authorization & Safety: Perform all activities only on the ICDFA-provided virtual machines, packet captures and isolated training networks. Do not bridge these VMs to production networks, scan external systems, or reuse credentials observed in training data.

Learning Outcomes

- Use Wireshark display filters to analyze provided ICS packet captures.
- Recognize HTTP, FTP, Modbus, DNP3, EtherNet/IP and S7 communication.
- Identify device, protocol and credential-exposure indicators in recorded traffic.
- Explain security weaknesses visible in legacy or cleartext industrial communications.
- Produce a concise packet-analysis report without interacting with any external system.

Laboratory Environment

System	Expected Address	Account	Password
Analyst/Kali VM	172.16.2.5 (teaching image)	kali	kali

Note: If the instructor-provided VM image uses updated addressing or credentials, use the values published in E-Campus. Do not alter addressing unless instructed.

Pre-Lab Checklist

- Read the complete lab before beginning.
- Confirm you can access the required VM(s) and that virtualization support is enabled.
- Use the instructor-specified isolated/host-only network.
- Create or restore the clean starting snapshot for this lab.
- Prepare a report document with your name, registration number, course, lab number and date.
- Capture evidence as you progress rather than repeating the lab at the end.

Procedure

Step 1. Start the ICDFA analyst VM in an isolated environment. This lab uses instructor-provided packet captures only; no scanning, exploitation or credential reuse is required.

Step 2. Open Wireshark and load the first instructor-provided ICS capture (for the teaching dataset this may be 4SICS-GeekLounge-151021.pcap).

Step 3. Apply the filter `http.authbasic`. Inspect the HTTP Authorization field and determine whether Basic authentication material is present. If you decode an encoded value for learning purposes, do so only within the provided capture and redact the recovered credential from submitted screenshots.

Step 4. Clear the filter and apply `http.request.method`. Refine to `http.request.method == "POST"` and inspect form submissions, request paths and response status codes. Record security-relevant observations without attempting to log in to any identified device.

Step 5. Apply `ftp` and inspect the FTP session metadata. Record any product/vendor or software-version information visible in the capture.

Step 6. Apply `modbus` and identify at least two Modbus function codes. If the second teaching capture is supplied, open it and compare the volume/types of Modbus traffic.

Step 7. Apply `dnp3` and identify a DNP3 conversation. Record source/destination systems and explain why DNP3 is common in process automation/SCADA environments.

Step 8. Apply `enip` and inspect available EtherNet/IP/CIP traffic. Record the key header/protocol details visible in the capture.

Step 9. Apply `s7comm` and inspect an S7 communication exchange. Record source/destination information and any Read Var or comparable operation visible.

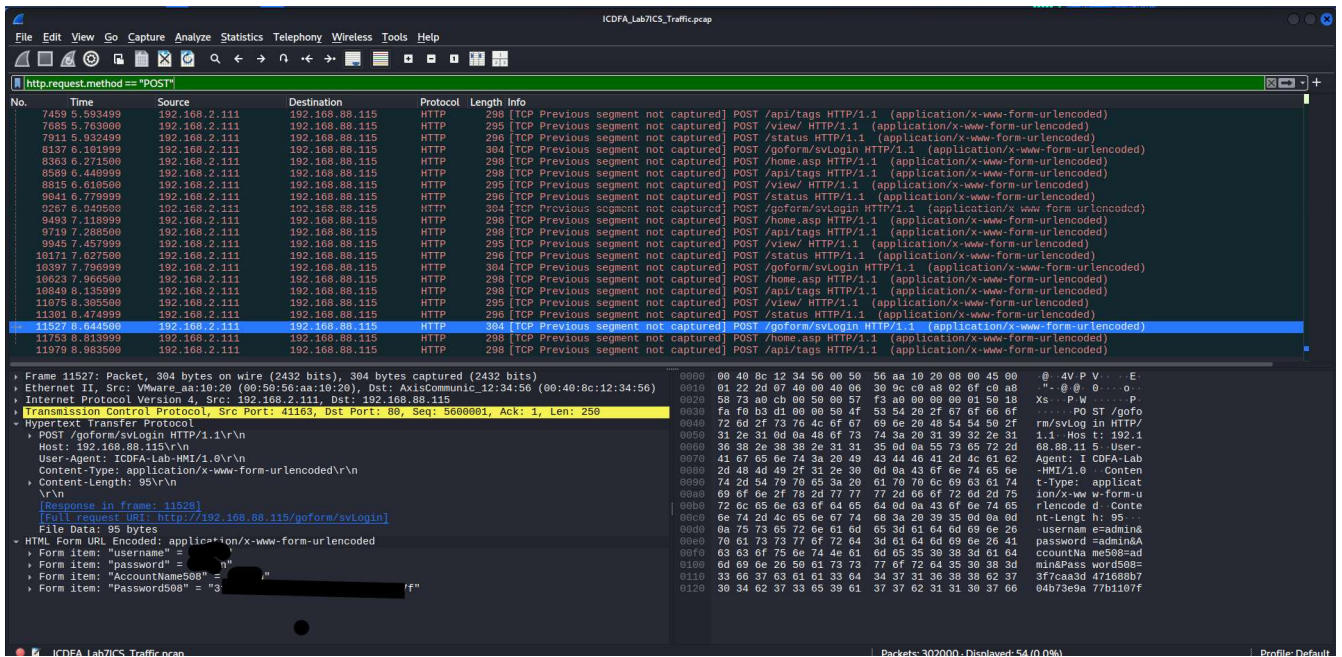
Step 10. Complete the Protocol Evidence Matrix for HTTP, FTP, Modbus, DNP3, EtherNet/IP and S7.

Step 11. Write a security assessment identifying at least five observations such as cleartext/encoded credentials, legacy protocols, exposed device metadata, insufficient confidentiality or excessive network visibility.

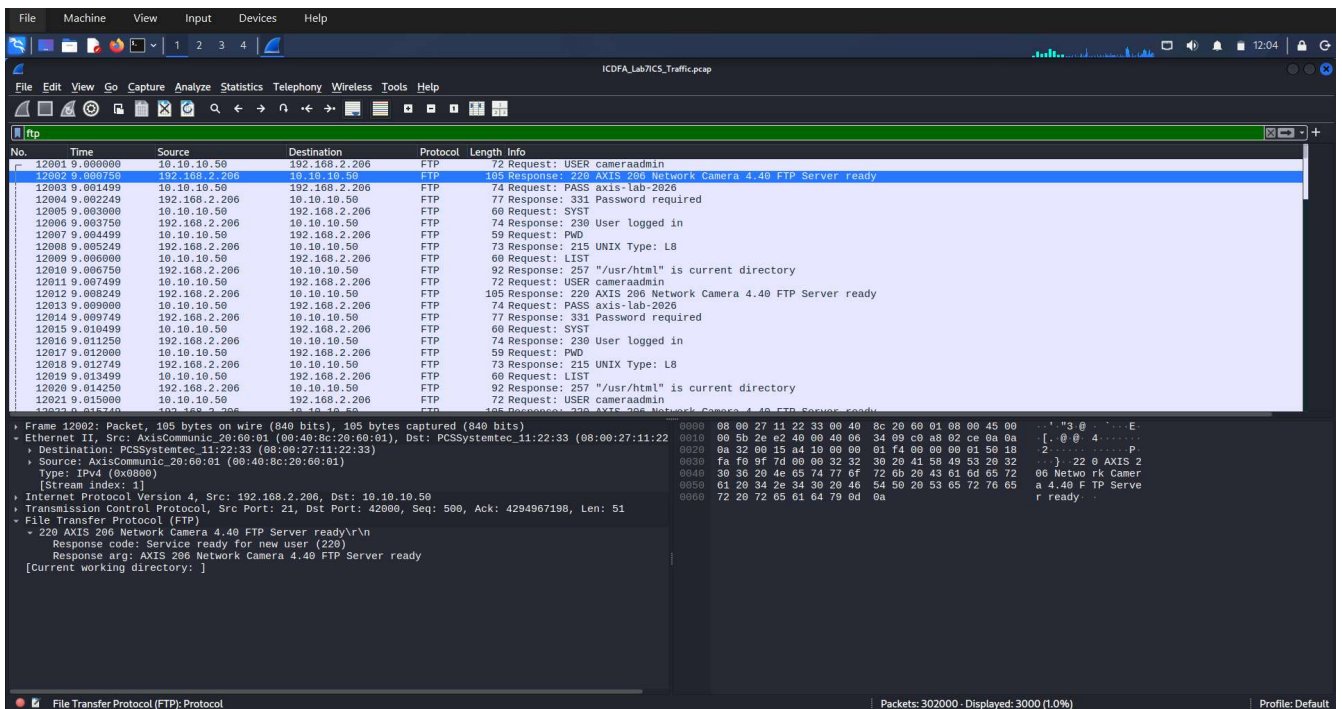
Step 12. Save your Wireshark workspace/screenshots and submit the report. Do not use any discovered credentials, addresses or device information outside the provided training material.

INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY (ICDFA)

INTRO TO CRITICAL INFRASTRUCTURE FOR IT LEARNERS

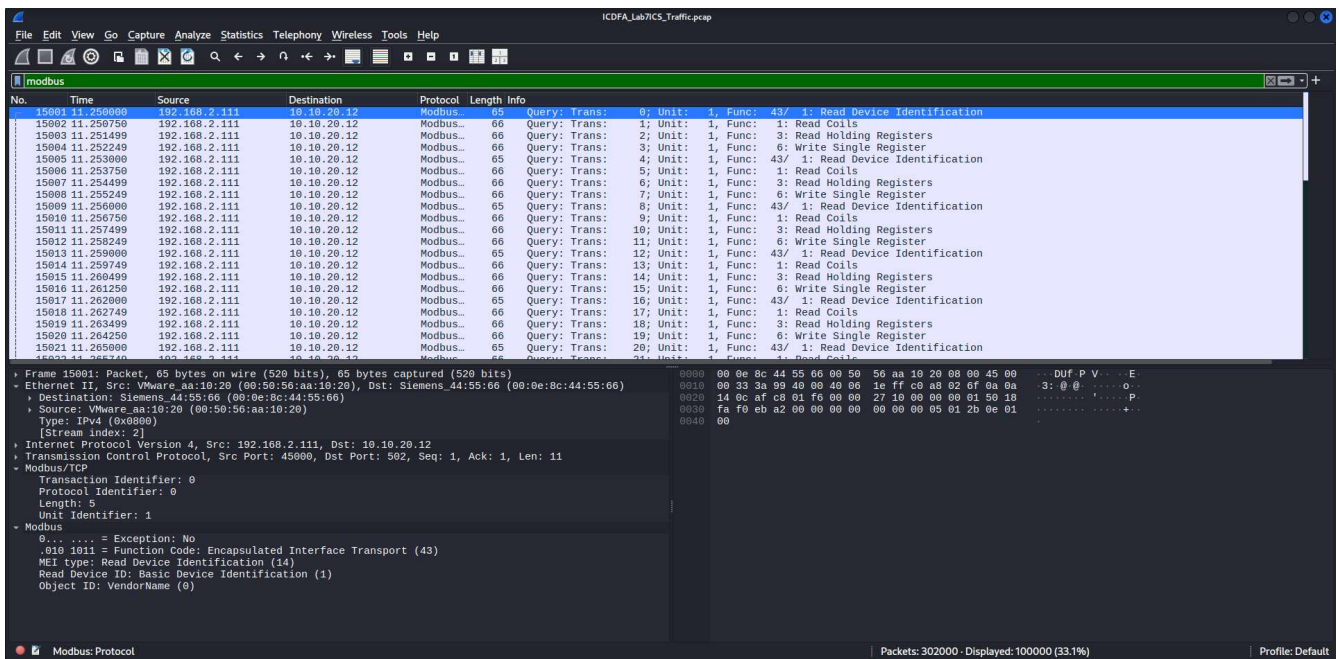


IMG: HTTP Analysis.

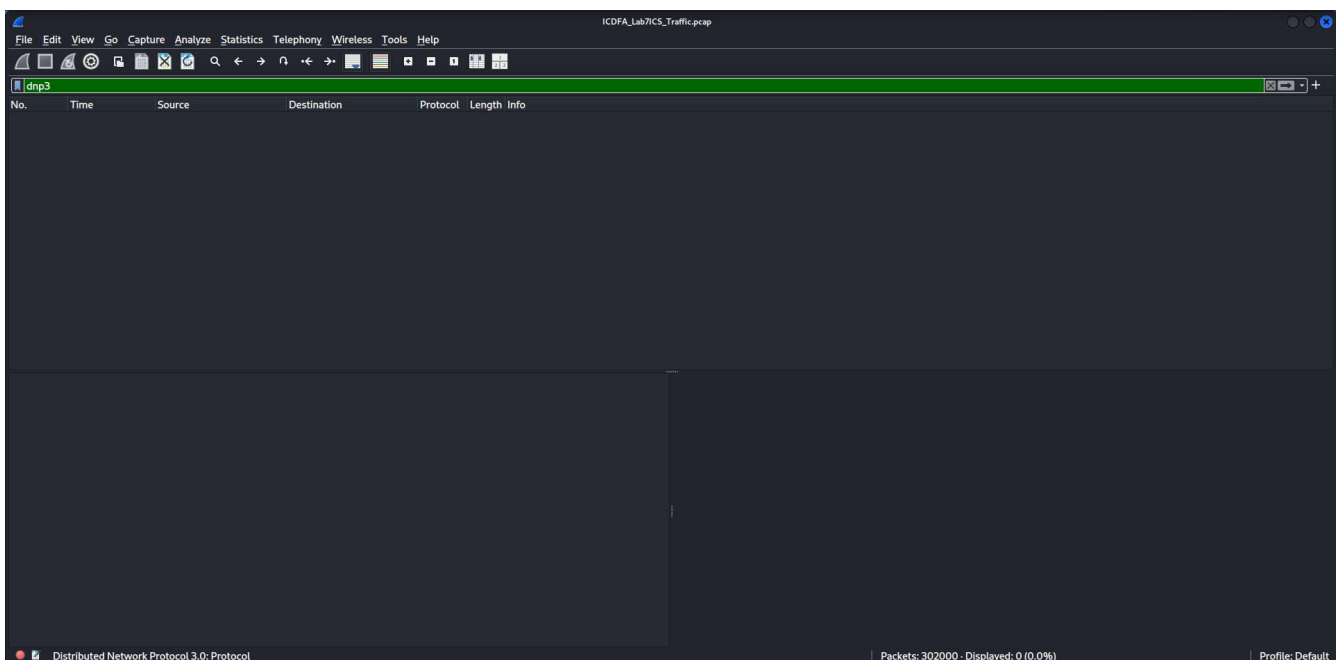


IMG: FTP Analysis.

INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY (ICDFA)
INTRO TO CRITICAL INFRASTRUCTURE FOR IT LEARNERS

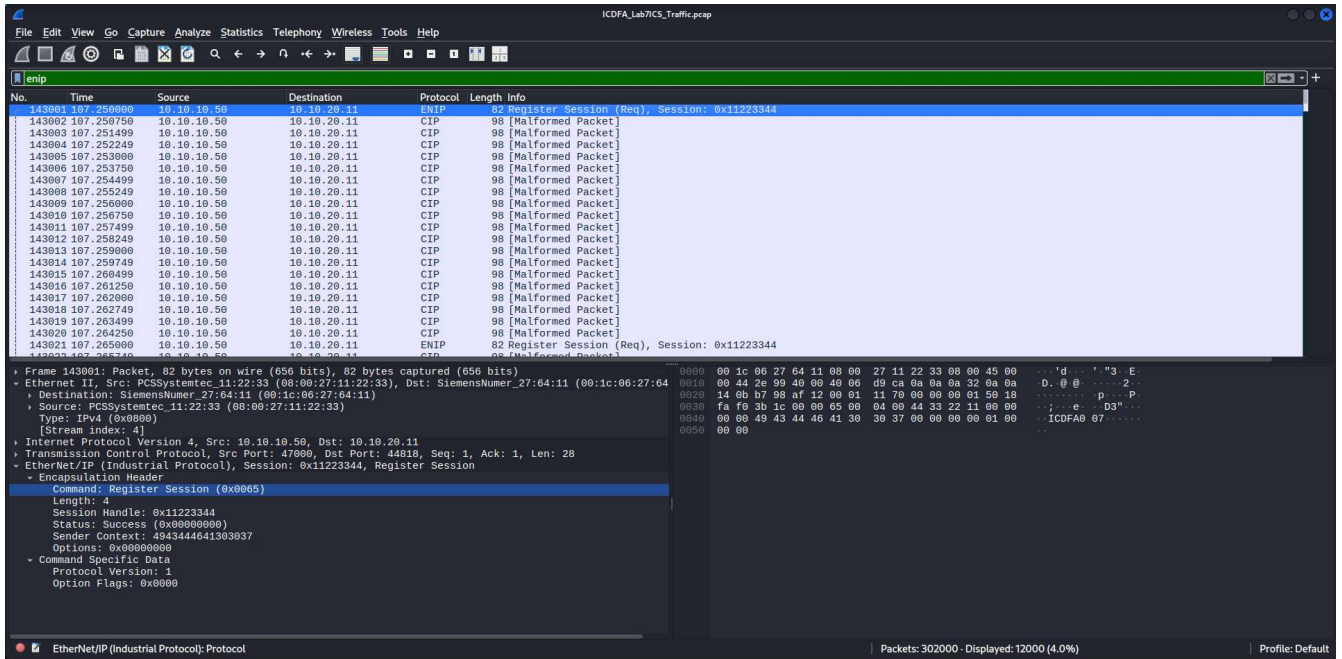


IMG: Modbus Analysis.

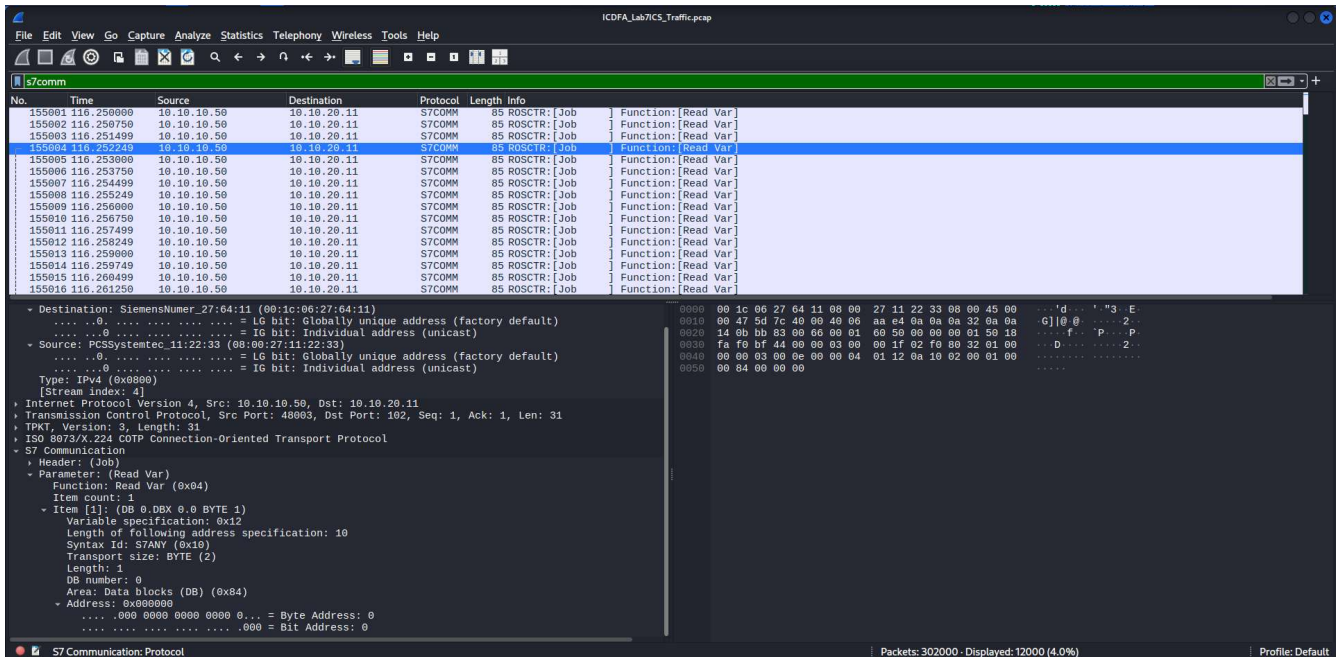


IMG: DNP3 Analysis (Absent in .pcap file).

INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY (ICDFA)
INTRO TO CRITICAL INFRASTRUCTURE FOR IT LEARNERS



IMG: Ethernet/IP Analysis.



IMG: S7 communications Analysis.

Wireshark Filter	Endpoints (Source → Dest)	Observed Operations	Security Significance
http.authbasic	192.168.2.111 → 192.168.88.115	The HTTP Authorization: Basic header transmits credentials in a Base64-encoded format that easily decodes to reveal the plaintext username and password.	Transmitting cleartext credentials across the network allows passive eavesdroppers to trivially intercept login details, enabling unauthorized access, session compromise, and potential lateral movement across the control network.
http.request.method == "POST"	192.168.2.111 → 192.168.88.115	An HTTP POST request transmits a static, unsalted SHA-256 hashed password parameter within the unencrypted TCP stream payload.	While SHA-256 is a one-way hashing algorithm rather than reversible encryption, sending a bare unsalted hash across cleartext HTTP leaves credentials exposed to immediate rainbow table lookups, offline dictionary attacks, and direct pass-the-hash replay attacks.
ftp	10.10.10.50 → 192.168.2.206	The FTP server welcome response (Code 220) broadcasts the specific embedded device name, model number, and software version immediately upon TCP connection before user authentication.	Exposing explicit system metadata allows an attacker to fingerprint the industrial device, research known hardware or firmware vulnerabilities, and craft highly targeted exploits without needing valid credentials.
modbus	192.168.2.111 → 10.10.20.12	The TCP stream captures Modbus TCP Function Code 43 (Read Device Identification) queries.	Exposing device identification metadata without authentication allows an adversary to fingerprint the industrial controller, research hardware and firmware-specific vulnerabilities, and prepare precise exploits against the target.
s7comm	10.10.10.50 → 10.10.20.11	The Ethernet II frame headers carrying S7comm traffic display source and destination MAC addresses, with the Organizationally Unique Identifier (OUI) prefix explicitly exposing the physical hardware manufacturer.	Exposing physical MAC addresses and OUIs allows an attacker to passively execute Layer 2 hardware fingerprinting, enabling them to identify PLC network cards, map physical network topology, and inventory vendor assets without sending a single active probe.

OT/ICS Security Assessment Report

A technical security evaluation was conducted on captured network traffic involving web management interfaces and industrial fieldbus protocols. The assessment revealed two primary threat vectors: cleartext transmission of administrative authentication data, and pervasive device information exposure across multiple network layers. An adversary on the local network can intercept administrative passwords, collect password hashes for offline cracking, and accurately map hardware vendors, model numbers, and firmware revisions across the OT environment.

Prioritized Findings & Risk Analysis

Priority 1 (Critical Severity): Cleartext Credential Exposure via HTTP Basic Authentication: The HTTP Authorization: Basic header transmits administrative credentials in a Base64-encoded format that easily decodes to reveal the plaintext username and password. Because Base64 is a simple data formatting scheme without cryptographic protection, any passive eavesdropper on the network stream can instantly recover valid login credentials and gain unauthorized administrative access to the system.

Priority 2 (High Severity): Unsalted Password Hash Transmission via HTTP POST: An HTTP POST request transmits a static, unsalted SHA-256 hashed password parameter within the unencrypted TCP stream payload. While SHA-256 is a one-way function, sending a bare, unsalted hash across cleartext HTTP leaves credentials vulnerable to immediate rainbow table lookups, offline dictionary attacks, and direct pass-the-hash replay attacks.

Priority 3 (Medium Severity): Active Asset Fingerprinting via Modbus Device Identification (FC43): The TCP stream captures Modbus TCP Function Code 43 (Read Device Identification) queries that return detailed plaintext responses containing the vendor name, product code, model, and exact firmware revision of the PLC. This protocol-level exposure allows adversaries to passively inspect or actively query control assets to identify exact software builds and plan targeted exploits.

Priority 4 (Medium Severity): Embedded Device Information Exposure via FTP Service Banner: The FTP server welcome response (Code 220) broadcasts the specific embedded device name, model number, and software version immediately upon TCP connection establishment prior to user authentication. Exposing explicit system metadata at the service layer enables attackers to conduct automated reconnaissance and match installed hardware against publicly known vulnerabilities without needing valid user credentials.

Priority 5 (Low Severity): Physical Hardware Vendor Identification via S7comm Ethernet MAC OUIs: The Ethernet II frame headers carrying S7comm traffic display source and destination MAC addresses containing explicit Organizationally Unique Identifier (OUI) prefixes that reveal the physical hardware manufacturer (such as Siemens). Attackers monitoring Layer 2 network traffic can analyze these physical addresses to map control hardware vendors and inventory physical assets without issuing a single active port scan.

Recommended Remediation Roadmap

Short-Term Fixes (Compensating Controls)

- Enforce management interface encryption by immediately migrating all HTTP traffic to HTTPS (TLS 1.3), preventing network listeners from sniffing Base64-encoded headers and SHA-256 POST parameters.
- Disable unencrypted FTP services or sanitize the FTP service banner configuration to remove device names, model numbers, and software version details from response Code 220.
- Configure passive intrusion detection system (IDS) sensors with custom rules to generate alerts whenever Modbus Function Code 43 queries are detected or when unencrypted management protocols are observed on the industrial segment.

Long-Term Architectural Improvements

- Upgrade HMI and web application authentication mechanisms to use slow, salted cryptographic hashing functions (such as Argon2 or bcrypt) rather than static, unsalted SHA-256 parameters.
- Implement strict network segmentation, VLAN isolation, and firewall Access Control Lists (ACLs) to restrict S7comm and Modbus TCP traffic, limiting Layer 2 MAC address visibility and blocking unauthorized device identification queries.

Required Evidence & Submission

- At least six protocol-analysis screenshots, one for each required protocol family.
- A Protocol Evidence Matrix with filters, endpoints, observed operations and security significance.
- A one-page security assessment prioritizing the observed risks.
- Redacted evidence of any credential material; plaintext credentials must not appear in the submitted report.

Recommended filename: <RegistrationNo>_LAB07_Exploring_ICS_Packet_Captures.pdf

Knowledge Check

1. Why does Base64 encoding not provide confidentiality for HTTP Basic authentication?

Response: Base64 is a reversible data formatting scheme rather than an encryption algorithm, meaning anyone who intercepts the encoded string can immediately convert it back to cleartext credentials without needing a secret key.

2. What information can device banners or protocol metadata reveal to an analyst?

Response: Device banners and protocol metadata expose specific technical details including hardware vendors, exact model numbers, installed firmware versions, operating systems, and supported protocol feature sets.

3. How do Modbus, DNP3, EtherNet/IP and S7 differ from ordinary user-facing protocols such as HTTP or FTP?

Response: Industrial protocols carry real-time command logic and sensor telemetry to directly control physical equipment on factory floors, whereas protocols like HTTP or FTP strictly deliver web pages and user files for human interaction.

4. Why is passive packet analysis valuable for understanding an ICS environment?

Response: Passive analysis safely maps device inventories, network baselines, and active communication flows by listening to live traffic, avoiding active probes that could trip or crash sensitive industrial controllers.

5. What compensating controls can reduce risk where legacy industrial protocols cannot be replaced immediately?

Response: Risk can be mitigated by isolating legacy traffic behind strict firewall segmentation and VLANs, wrapping unencrypted industrial protocols inside secure VPN tunnels, and deploying passive intrusion detection systems to alert on unauthorized commands.

Marking Rubric — 100 Marks

Criterion	Marks	Standard
Technical execution	50	Lab procedure completed correctly; required configuration/analysis works as intended.
Evidence	20	Screenshots/files are complete, readable, relevant and clearly labelled.
Analysis & knowledge check	20	Responses demonstrate understanding of the industrial-control concepts observed.
Professional reporting	10	Clear structure, correct terminology, concise writing, file naming and submission compliance.
Submission Integrity: Evidence must come from the student's own assigned laboratory environment. Screenshots should show enough context to verify the activity. Do not submit another learner's screenshots or project files.		